SentinelWP — WordPress Security Assessment

Target URL: http://127.0.0.1:8099 | **Scan ID:** 2c91f503 | **Generated:** 2026-10-11 06:40 UTC

Executive Summary

Overall Risk Score	**85.3 / 100**	**Security Grade**	**F**
WordPress CMS	Yes	**Core WP Version**	6.4.3
Total Findings	**48**	**Scanner Engine**	SentinelWP v3.6.0 Enterprise

CRITICAL	HIGH	MEDIUM	LOW	INFO
1	6	10	28	3

EXECUTIVE NARRATIVE: CRITICAL EXECUTIVE ATTENTION REQUIRED

The security assessment performed on target **http://127.0.0.1:8099** identified a **high risk exposure profile**. A total of **48 findings** were detected, including **1 Critical** and **6 High severity vulnerabilities**. Immediate emergency patch deployment and incident mitigation procedures are strongly recommended within a 48-hour SLA window to prevent unauthorized access, system compromise, or data exposure.

PRIORITIZED REMEDIATION ACTION PLAN FOR DECISION-MAKERS & TECHNICAL TEAMS:
• **PHASE 1 — Emergency Patching (0 - 48h SLA):** Remediate all vulnerabilities listed in CISA KEV or with Critical CVSS ≥ 9.0.
• **PHASE 2 — Hardening & Upgrades (7 - 14 Days SLA):** Apply updates for High/Medium components and enforce HTTP security headers (CSP, HSTS, X-Frame-Options).
• **PHASE 3 — Continuous Intelligence & Compliance (Ongoing SLA):** Maintain scheduled automated audits integrated with Wordfence and CISA KEV threat feeds.

Detailed Vulnerability & Finding Log

Severity	Category	Title & CVE	Description & Action
INFO	information_disclosure	**WordPress CMS Detected**	WordPress detected at http://127.0.0.1:8099 (confidence: 100%) — Version: 6.4.3 (source: meta_generator, reliability: high) **Action:** Remove version meta tags and generator references from page source.
MEDIUM	information_disclosure	**WordPress Version Exposed: 6.4.3**	WordPress version (6.4.3) is publicly visible. Source: meta_generator (reliability: high). This enables targeted exploit research. **Action:** Remove the generator meta tag. Use security plugins to hide version info.
HIGH	enumeration	**REST API WAF/Rewrite Bypass for User Enumeration (?rest_route=/wp/v2/users)**	Path-based blocking on /wp-json/wp/v2/users was bypassed using the query parameter ?rest_route=/wp/v2/users. Disclosed 1 user account(s). **Action:** Ensure WAF and rewrite rules inspect both URL paths and query parameters (?rest_route=). Disable the endpoint at application level using the rest_endpoints filter.

Severity	Category	Title & CVE	Description & Action
HIGH	enumeration	**Author Archive User Enumeration**	User enumeration via author archives or RSS feeds is possible. Identified 1 public author account(s). **Action:** Disable author archives or redirect them. Add to .htaccess: RewriteCond %{QUERY_STRING} ^author= [NC] RewriteRule .* - [F,L]. Alternatively use a plugin to disable author enumeration.
LOW	exposure	**wp-admin Publicly Accessible (Login Required)**	The /wp-admin/ path is publicly reachable and redirects to login. Consider restricting access by IP or VPN. **Action:** Restrict /wp-admin/ access via .htaccess IP whitelist, VPN requirement, or a WAF rule. Example: <Files wp-login.php> Order Deny,Allow Deny from all Allow from YOUR_IP </Files>
LOW	exposure	**install.php Accessible (Already Installed)**	wp-admin/install.php is publicly accessible. While WordPress reports already installed, this endpoint should be blocked. **Action:** Block access to install.php via .htaccess or server rules.
LOW	information_disclosure	**WordPress readme.html Accessible**	readme.html is publicly readable and confirms WordPress installation. **Action:** Delete or block access to readme.html via server configuration.
LOW	information_disclosure	**WordPress license.txt Accessible**	license.txt is publicly readable and confirms WordPress installation. Version reference found: 2 **Action:** Delete or block access to license.txt via server configuration.
LOW	exposure	**wp-cron.php Publicly Accessible**	wp-cron.php is accessible. On high-traffic sites this can be used for DoS. It also reveals that WordPress is installed. **Action:** Disable wp-cron via wp-config.php (define('DISABLE_WP_CRON', true)) and use a system cron job instead. Block public access via .htaccess.
HIGH	headers	**Missing Security Header: Strict-Transport-Security**	HSTS header missing. Browser may allow HTTP connections, enabling MITM attacks. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
MEDIUM	headers	**Missing Security Header: Content-Security-Policy**	CSP header missing. The site is more vulnerable to XSS and injection attacks. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Implement a Content-Security-Policy header appropriate for your site.
MEDIUM	headers	**Missing Security Header: X-Content-Type-Options**	X-Content-Type-Options header missing. Browser may MIME-sniff responses. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: X-Content-Type-Options: nosniff
MEDIUM	headers	**Missing Security Header: X-Frame-Options**	X-Frame-Options header missing. The site may be vulnerable to clickjacking. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: X-Frame-Options: DENY (or SAMEORIGIN if framing is needed internally).

Severity	Category	Title & CVE	Description & Action
LOW	headers	**Missing Security Header: Referrer-Policy**	Referrer-Policy header missing. Full URL may be sent as referrer to third parties. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: Referrer-Policy: strict-origin-when-cross-origin
LOW	headers	**Missing Security Header: Permissions-Policy**	Permissions-Policy header missing. Browser features are not explicitly restricted. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add a Permissions-Policy header to restrict unnecessary browser features (camera, microphone, geolocation).
LOW	headers	**Missing Security Header: X-XSS-Protection**	X-XSS-Protection header missing (relevant for older browsers). (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: X-XSS-Protection: 1; mode=block (or 0 if CSP is properly configured).
LOW	headers	**Missing Security Header: Cross-Origin-Opener-Policy**	Cross-Origin-Opener-Policy (COOP) header missing. Isolates top-level browsing context from cross-origin windows. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: Cross-Origin-Opener-Policy: same-origin
LOW	headers	**Missing Security Header: Cross-Origin-Resource-Policy**	Cross-Origin-Resource-Policy (CORP) header missing. Restricts cross-origin resource reading and embedding. (Note: this is a general hardening recommendation, not a WordPress-specific vulnerability.) **Action:** Add header: Cross-Origin-Resource-Policy: same-origin (or same-site)
LOW	headers	**Information Disclosure Header: Server**	Server header exposes web server software and version. Value: Apache/2.4.57 (Debian) **Action:** Remove or obfuscate the Server header in your web server configuration.
LOW	headers	**Information Disclosure Header: X-Powered-By**	X-Powered-By header exposes backend technology. Value: PHP/8.2.17 **Action:** Remove the X-Powered-By header. PHP: expose_php = Off in php.ini.
MEDIUM	headers	**Server Banner Reveals Version Details**	The Server header contains version information: 'Apache/2.4.57 (Debian)'. This assists attackers in identifying exploitable software versions. **Action:** Configure the web server to suppress version numbers. Apache: ServerTokens Prod. Nginx: server_tokens off;
CRITICAL	encryption	**Site Not Using HTTPS**	The target URL uses HTTP instead of HTTPS. All traffic is unencrypted. **Action:** Configure TLS/SSL certificate and redirect all HTTP traffic to HTTPS.
INFO	information_disclosure	**Theme Identified: twentytwentyfour**	Active theme detected from page source: twentytwentyfour (version 1.0, confidence: high) **Action:** Consider hiding theme paths with a security plugin.

Severity	Category	Title & CVE	Description & Action
LOW	information_disclosure	**Default Theme Present: twentytwentyfour**	Default WordPress theme 'twentytwentyfour' detected on server (version 1.0, confidence: high). Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwentyfour' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentytwentythree**	Default WordPress theme 'twentytwentythree' detected on server (version 1.3, confidence: high). Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwentythree' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentytwentytwo**	Default WordPress theme 'twentytwentytwo' detected on server (version 1.6, confidence: high). Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwentytwo' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentytwentyone**	Default WordPress theme 'twentytwentyone' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwentyone' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentytwenty**	Default WordPress theme 'twentytwenty' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwenty' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentynineteen**	Default WordPress theme 'twentynineteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentynineteen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentyeighteen**	Default WordPress theme 'twentyeighteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentyeighteen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentyseventeen**	Default WordPress theme 'twentyseventeen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentyseventeen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentysixteen**	Default WordPress theme 'twentysixteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentysixteen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentyfifteen**	Default WordPress theme 'twentyfifteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentyfifteen' from wp-content/themes/ if not in use.

Severity	Category	Title & CVE	Description & Action
LOW	information_disclosure	**Default Theme Present: twentyfourteen**	Default WordPress theme 'twentyfourteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentyfourteen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentythirteen**	Default WordPress theme 'twentythirteen' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentythirteen' from wp-content/themes/ if not in use.
LOW	information_disclosure	**Default Theme Present: twentytwelve**	Default WordPress theme 'twentytwelve' detected on server. Unused themes should be removed to reduce attack surface. **Action:** Delete unused default theme 'twentytwelve' from wp-content/themes/ if not in use.
MEDIUM	configuration	**No WAF Detected**	No Web Application Firewall was detected. The application may be directly exposed to attacks. **Action:** Consider deploying a WAF (Cloudflare, Sucuri, AWS WAF, or ModSecurity).
HIGH	authentication	**XML-RPC system.multicall Available**	system.multicall is enabled, allowing attackers to attempt thousands of password guesses in a single HTTP request. Total methods available: 80. **Action:** Disable XML-RPC or specifically block system.multicall. Use a security plugin to disable multicall or rate-limit attempts.
MEDIUM	exposure	**XML-RPC Pingback Available (DDoS Vector)**	pingback.ping method is available. This can be abused for DDoS amplification and internal port scanning (SSRF). **Action:** Disable pingbacks: add_filter('xmlrpc_methods', function($methods) { unset($methods['pingback.ping']); return $methods; });
MEDIUM	enumeration	**XML-RPC User Methods Available**	User-related XML-RPC methods are available (wp.getUsersBlogs, wp.getUsers). These can be used for credential testing. **Action:** Disable XML-RPC or restrict these methods via security plugin.
LOW	information_disclosure	**XML-RPC Methods Enumerated: 80 methods**	system.listMethods returned 80 available methods. **Action:** Disable system.listMethods or restrict XML-RPC access entirely.
MEDIUM	configuration	**Cookies Missing Secure Flag**	The following cookie(s) are missing the 'Secure' flag: wordpress_test_cookie. Cookies without the Secure flag can be transmitted over unencrypted HTTP connections, exposing sensitive data to interception via man-in-the-middle (MITM) attacks. **Action:** Configure the server to include the 'Secure' attribute for all Set-Cookie headers.
MEDIUM	configuration	**Cookies Missing HttpOnly Flag**	The following cookie(s) are missing the 'HttpOnly' flag: wordpress_test_cookie. Cookies without HttpOnly can be accessed by client-side JavaScript, making them vulnerable to theft via Cross-Site Scripting (XSS) attacks. **Action:** Set the 'HttpOnly' attribute on all cookies, especially session cookies.

Severity	Category	Title & CVE	Description & Action
LOW	configuration	**Cookies Missing SameSite Attribute**	The following cookie(s) are missing the 'SameSite' attribute: wordpress_test_cookie. Without SameSite, cookies may be included in cross-site requests, increasing vulnerability to Cross-Site Request Forgery (CSRF) attacks. **Action:** Set the 'SameSite' attribute ('Strict' or 'Lax') on all cookies.
INFO	information_disclosure	**WHOIS Information Retrieved**	WHOIS lookup succeeded for 0.1. Registrar: Unknown | Expiration Date: Unknown. **Action:** No remediation needed. Keep domain registration details updated.
LOW	configuration	**Missing Security Policy File (security.txt)**	No security policy file (security.txt) was found in /.well-known/security.txt or /security.txt. It is a best practice to publish contact info for vulnerability disclosure. **Action:** Create a security.txt file adhering to RFC 9116 and place it in the /.well-known/ directory.
HIGH	encryption	**Missing SPF Record**	Domain 127.0.0.1 is missing an SPF (Sender Policy Framework) TXT record. Spammers can spoof email originating from this domain, damaging brand reputation. **Action:** Create a TXT record for the domain with a valid SPF configuration (e.g., 'v=spf1 include:_spf.example.com ~all').
HIGH	encryption	**Missing DMARC Record**	Domain 127.0.0.1 is missing a DMARC record. This increases vulnerability to email phishing, spoofing, and brand abuse. **Action:** Add a TXT record at _dmarc.yourdomain.com with policy settings, e.g., 'v=DMARC1; p=quarantine; pct=100; rua=mailto:security@yourdomain.com'.